

Políticas de privacidade e backup

O avanço da digitalização consolidou a informação como um ativo central para a maior parte das organizações (sejam elas públicas, privadas ou de terceiro setor), tornando o armazenamento e a proteção de dados elementos críticos na gestão de riscos em ambientes tecnológicos. Diante de possíveis interrupções de serviços, falhas técnicas, incidentes de segurança ou até mesmo desastres naturais, a definição de políticas de privacidade e rotinas de backup deixou de ser apenas uma boa prática e passou a representar uma exigência estratégica para a continuidade dos negócios.

Neste capítulo será apresentada uma visão integrada de dois pontos fundamentais e complementares – a privacidade dos dados e a implementação de estratégias de backup –, ambos impulsionados por motivações que refletem a crescente importância da segurança da informação. O propósito é destacar processos que assegurem a confidencialidade, a integridade e a disponibilidade das informações, em conformidade com legislações e normas vigentes, e que estejam adaptados às demandas específicas de cada organização.

Ao longo do texto, o leitor será conduzido a refletir sobre a relevância de se proteger dados sensíveis e estruturar políticas de backup que sejam consistentes, escaláveis e capazes de acompanhar as transformações tecnológicas e operacionais.

Na primeira parte deste material textual, serão explorados os papéis do backup e da privacidade como práticas que reduzem riscos, garantem a recuperação de informações críticas e preservam a imagem institucional. Em seguida, serão tratados os fundamentos necessários para a elaboração de políticas de backup, incluindo a gestão do consentimento, a proteção de dados confidenciais, além de critérios para retenção e descarte de informações, sempre pautados pela conformidade legal e pela responsabilidade ética.

O planejamento da recuperação também será analisado, com ênfase em diferentes modelos de armazenamento (tanto em infraestrutura local quanto em soluções em nuvem), destacando estratégias que viabilizem a restauração ágil de dados em situações de crise. Nesse contexto, serão avaliados aspectos como custos, tempo de resposta e níveis de segurança, de modo a apoiar decisões mais eficazes.

Ao final, o capítulo discute a integração entre privacidade, backup e gestão de riscos, evidenciando como a proteção das informações está diretamente relacionada à segurança dos sistemas. Serão apresentadas práticas de monitoramento contínuo, revisões periódicas das políticas adotadas e a utilização de indicadores de desempenho (KPIs) para mensurar a efetividade das ações implementadas.

Ao concluir a leitura, espera-se que o leitor compreenda como alinhar políticas de backup e privacidade ao contexto organizacional, fortalecendo a resiliência das operações e minimizando vulnerabilidades.

1 Importância do backup e da privacidade de dados

A cada segundo, empresas e indivíduos geram volumes imensos de dados sensíveis, que variam de informações pessoais a registros financeiros e ativos críticos. Quando esses dados são perdidos ou expostos, as consequências atingem a confiança, a imagem da organização e podem acarretar sanções legais. A legislação vigente no Brasil, como a Lei Geral de Proteção de Dados (LGPD) (Brasil, 2018), impõe obrigações claras em relação a proteção, retenção e segurança das informações. Também nesse contexto, o backup deixa de ser apenas uma salvaguarda técnica e passa a ser um movimento estratégico para manter operações acessíveis, seguras e conformes.

O conceito de backup refere-se à criação de cópias de segurança de dados, arquivos, sistemas ou informações, realizadas com o objetivo de protegê-los contra perda, corrupção ou exclusão accidental. O backup permite que, caso ocorra algum problema, os dados possam ser restaurados e recuperados, garantindo a continuidade das operações (Machado, 2014).

A utilização de rotinas regulares de cópia de segurança ajuda a mitigar os efeitos de incidentes, oriundos de ataques cibernéticos e/ou de simples falhas humanas. Assim, este processo de backup permite restabelecer sistemas em poucos momentos e reduzir prejuízos que seriam relativamente grandes. Por isso, as organizações que adotam políticas bem-estruturadas evitam interrupções prolongadas e limitam os impactos operacionais e financeiros decorrentes de incidentes inesperados.

Além disso, a privacidade dos dados (especialmente os sensíveis) requer mecanismos que ultrapassem o simples ato de armazená-los. Recursos como criptografia, autenticação multifator e práticas de governança alinhados a padrões organizacionais contribuem para definir responsabilidades e assegurar o uso ético e seguro das informações. Quando bem-estruturada, a governança estabelece uma base sólida para que os processos estejam em sintonia com a realidade da organização, tratando os dados como ativos valiosos cujos fluxos e características precisam ser administrados com clareza e responsabilidade.

Proteger informações significa manter a continuidade dos serviços, preservar a confiança de colaboradores, clientes e parceiros e minimizar riscos legais e de reputação. A implementação de políticas de backup e de privacidade de dados, aliada a soluções tecnológicas e a uma cultura organizacional voltada à segurança, fortalece a gestão de riscos e contribui para a estabilidade das operações.

1.1 Fundamentos de política de backup

Uma política de backup representa um conjunto de diretrizes que orienta como as cópias de segurança serão realizadas, armazenadas e mantidas dentro de uma organização. Ela define desde os objetivos do processo até as responsabilidades das equipes envolvidas, servindo como referência para garantir a disponibilidade e a integridade das informações (Machado, 2014).

Para que essa política seja eficiente, é necessário avaliar o contexto de cada ambiente de TI. Organizações que lidam com sistemas de atendimento ao cliente, por exemplo, podem adotar backups em intervalos curtos, a fim de evitar a perda de dados de transações realizadas ao longo do dia. Já em sistemas de processamento de relatórios mensais, a frequência pode ser mais espaçada, desde que alinhada ao risco aceitável para a operação (Varela, 2020).

De acordo com Pegetti (2022), uma política bem-elaborada deve contemplar elementos como:

- Identificação das informações (quais dados e sistemas precisam ser copiados).
- Definição da frequência (diária, semanal, mensal ou até múltiplas vezes por dia em sistemas críticos).
- Armazenamento e proteção da mídia (locais seguros, preferencialmente fora do ambiente físico da TI principal).
- Testes periódicos (verificação da integridade e capacidade de restauração das cópias).

Machado (2014) acrescenta que o processo de backup deve respeitar janelas de tempo adequadas, evitando conflitos com operações críticas da empresa. Isso significa, por exemplo, que em sistemas que funcionam continuamente (24 horas por dia, sete dias por semana), a execução precisa ocorrer em horários de menor atividade para reduzir a possibilidade de perda de dados recentes.

Para melhor entender as necessidades de backup e suas políticas, recorramos a um caso comum em empresas de comércio eletrônico. Considere que um servidor de vendas on-line registre milhares de pedidos por hora. Se o backup for programado apenas uma vez ao dia, qualquer incidente poderá resultar na perda de horas de transações, prejudicando clientes e gerando prejuízos. Nesse contexto, a política pode determinar backups “parciais” a cada poucas horas, combinados com backups completos em períodos mais longos, garantindo rapidez na restauração e menor consumo de recursos.

Outro aspecto relevante é a adaptação constante da política. À medida que a infraestrutura cresce, com novos servidores, sistemas e volumes de dados, a política precisa ser revista para incluir essas mudanças. Sem essa atualização, áreas recém-implantadas podem ficar sem cobertura adequada, abrindo brechas para incidentes (Kolbe Junior, 2017).

Para que a política de backup seja executada de forma adequada, é necessário compreender que existem diferentes classificações para o backup. Kolbe Junior (2020) apresenta uma primeira divisão baseada na finalidade e os classifica como:

- Backup de arquivamento: destinado a preservar informações que não sofrem alterações constantes, mantendo registros históricos para consulta futura ou por exigências legais. É comum em empresas que precisam guardar documentos fiscais, contratos ou registros contábeis por longos períodos.
- Backup operacional: voltado à cópia de dados utilizados no dia a dia da organização, com o objetivo de garantir a recuperação rápida em caso de falhas ou incidentes. Abrange sistemas de uso contínuo, como bancos de dados corporativos e plataformas de atendimento.

Além dessa divisão baseada na finalidade, Kolbe Junior (2020) e Machado (2014) também classificam os backups conforme a abrangência da atividade executada. Essa segunda classificação define a quantidade de dados copiados, a frequência e o método de atualização, como apresenta o quadro 1 a seguir.

Quadro 1 – Classificação dos backups quanto à abrangência da atividade

TIPO DE BACKUP	DESCRIÇÃO	CARACTERÍSTICAS E APLICAÇÕES	EXEMPLO
Completo	Cópia integral de todos os dados selecionados, independentemente de alterações.	Alta confiabilidade para restauração. Demanda maior tempo e espaço de armazenamento.	Backup semanal de todos os servidores de arquivos de uma empresa.
Incremental	Copia apenas os dados modificados desde o último backup (completo ou incremental).	Rápido e com menor uso de recursos, mas a restauração exige a última cópia completa e todas as incrementais subsequentes.	Backup a cada seis horas de arquivos alterados em um sistema de vendas.

(cont.)

TIPO DE BACKUP	DESCRIÇÃO	CARACTERÍSTICAS E APLICAÇÕES	EXEMPLO
Diferencial	Copia todos os dados alterados desde o último backup completo.	Restauração mais simples que o incremental (precisa apenas do último completo e do último diferencial), mas ocupa mais espaço.	Backup diário de sistemas administrativos baseado no último completo da semana.
Incremental progressivo	Similar ao incremental, mas permite que os backups subsequentes copiem somente as alterações desde o último incremental executado.	Menor volume de dados armazenados a longo prazo. Pode tornar a recuperação mais demorada, pois requer sequência de várias cópias.	Backup de sistemas de desenvolvimento de software, capturando alterações feitas ao longo do dia.
Incremental para sempre	Mantém um backup completo inicial e, a partir dele, realiza apenas incrementais contínuos.	Reduz consideravelmente o tempo de backup e o uso de armazenamento; recuperação depende de organização e controle rigoroso.	Serviços de nuvem que atualizam continuamente os arquivos de usuários, como em plataformas de backup contínuo.

Fonte: Kolbe Junior (2020) e Machado (2014).

Conhecer os diferentes tipos de backup e compreender suas características permite alinhar a política adotada às necessidades reais da organização. A escolha adequada influencia diretamente o tempo de recuperação, o volume de armazenamento necessário e a segurança das informações. Uma decisão equivocada, como utilizar um método de cópia lenta em um sistema que exige respostas rápidas, pode comprometer operações críticas e ampliar os impactos de um incidente.

1.1.1 Gestão de consentimento e proteção de dados sensíveis

A gestão de consentimento é o processo pelo qual a organização obtém, registra e administra a autorização do titular para coletar, processar e armazenar seus dados pessoais. No contexto da LGPD, o consentimento precisa ser informado, específico e registrado de forma clara, de

modo que o titular compreenda exatamente para quais finalidades seus dados serão utilizados. Em muitos casos, essa autorização também deve permitir que o usuário a revogue a qualquer momento, reforçando a transparência e a confiança no relacionamento com a instituição (Brasil, 2018).



IMPORTANTE

Dados sensíveis são informações pessoais que, devido à sua natureza, podem gerar riscos maiores aos direitos e à liberdade do titular, caso sejam tratados de forma inadequada.

A proteção de dados sensíveis exige atenção ainda maior. Esses dados incluem informações como origem racial ou étnica, convicções religiosas, opiniões políticas, dados relativos à saúde, vida sexual, dados genéticos ou biométricos. Pela natureza dessas informações, seu tratamento deve adotar medidas de segurança mais rigorosas, o que inclui o uso de criptografia, controle de acesso baseado em funções, anonimização ou pseudonimização, além de monitoramento contínuo de tentativas de acesso indevido (Brasil, 2018).

A pseudonimização é um procedimento de proteção de dados pessoais em que informações identificáveis, como nome, CPF ou endereço, são substituídas por identificadores artificiais ou códigos, de forma que o dado original não possa ser associado diretamente a uma pessoa sem o uso de informações adicionais mantidas separadamente.

Diferente da anonimização, em que o dado se torna irreversivelmente irreconhecível, a pseudonimização permite que, com o acesso a uma chave ou tabela específica, seja possível reidentificar o titular do dado. Por isso, ela é considerada uma medida de segurança que reduz riscos de exposição de informações pessoais, mas não elimina a necessidade de cumprimento da LGPD.



NA PRÁTICA

Como exemplo prático de pseudonimização podemos citar um banco de dados da área da saúde, em que os nomes dos pacientes são substituídos por códigos numéricos, e apenas um arquivo separado relaciona cada código ao paciente correspondente. Nesse contexto, os pesquisadores podem analisar os dados sem saber a identidade real dos indivíduos.

A ausência de uma gestão adequada de consentimento e proteção de dados sensíveis pode gerar sanções legais, além da perda de reputação e quebra de confiança perante clientes e parceiros. Por exemplo, em um sistema de saúde digital, o acesso não autorizado ao histórico clínico de pacientes pode acarretar penalidades severas e comprometer a credibilidade de todo o serviço.

Para que a política de backup esteja alinhada a essa proteção, é necessário que as cópias de segurança também respeitem as permissões e restrições estabelecidas no momento da coleta dos dados. Isso significa que um backup não pode simplesmente copiar indiscriminadamente todo o conteúdo de um banco de dados sem considerar quais informações requerem criptografia ou segregação.

Segundo Machado (2014) e Kolbe Junior (2020), a segurança das cópias deve incluir:

- Classificação prévia dos dados para identificar quais são sensíveis e quais não são.
- Aplicação de técnicas de proteção como criptografia e mascaramento de dados antes do armazenamento.
- Controle de acesso restrito às mídias ou sistemas de backup, permitindo que apenas pessoas autorizadas possam manipular ou restaurar as informações.

- Registro e auditoria de todas as operações de cópia e restauração para fins de conformidade e rastreabilidade.

Em ambientes corporativos, a integração entre a gestão de consentimento e a política de backup garante que a preservação das informações não viole direitos dos titulares nem descumpra normas regulatórias. Dessa forma, a organização protege seus ativos digitais e demonstra responsabilidade e comprometimento com a privacidade e a segurança da informação.

1.1.2 Políticas de retenção e exclusão de dados

A política de retenção e exclusão de dados define por quanto tempo uma informação deve ser mantida e quais procedimentos devem ser aplicados para o seu descarte seguro. Essa política precisa estar alinhada às exigências legais, contratuais e normativas que regulamentam cada setor, bem como às necessidades operacionais da organização. No contexto da LGPD, a guarda de informações pessoais deve estar restrita ao período necessário para o cumprimento de sua finalidade original, sendo obrigatória a exclusão ou anonimização quando essa finalidade é atingida (Brasil, 2018).

O processo de retenção considera diferentes tipos de dados e suas finalidades. Por exemplo, registros fiscais podem precisar ser mantidos por um período mínimo exigido pela legislação tributária (geralmente cinco anos), enquanto logs de sistemas podem ser guardados por um intervalo mais curto, apenas para fins de auditoria ou segurança. Já na exclusão, o objetivo é remover os dados de forma que não possam ser recuperados, utilizando métodos como sobrescrita segura (overwrite), destruição física de mídias ou ferramentas de sanitização digital compatíveis com normas internacionais de segurança da informação.

Segundo Machado (2014), a ausência de regras claras de retenção pode gerar acúmulo de informações desnecessárias, elevando custos

de armazenamento e aumentando o risco de exposição indevida. Além disso, manter dados além do prazo legal ou contratual expõe a organização a penalidades e compromete a conformidade regulatória. Nesse sentido, a política deve prever revisões periódicas para garantir que os prazos de guarda e os métodos de descarte sejam constantemente atualizados conforme mudanças na legislação ou no cenário tecnológico.

Como exemplo, em uma empresa do setor de saúde, prontuários eletrônicos podem ser retidos por dez anos (seguindo normativas específicas), mas relatórios temporários de exames podem ser excluídos em prazos menores, desde que não comprometam o atendimento ao paciente. Esse cuidado garante a preservação de dados relevantes e, ao mesmo tempo, reduz a exposição de informações que já não têm valor operacional.

A política de retenção e exclusão de dados atua como um mecanismo de controle no ciclo de vida da informação. Ao delimitar prazos e métodos seguros de descarte, contribui para a eficiência operacional, a proteção da privacidade e a conformidade legal, reforçando a postura responsável da organização no tratamento de dados.

2 Planejamento de backup e recuperação

Planejar o backup e a recuperação de dados é como montar um “plano B” para o funcionamento da organização. Ou seja, pensar estrategicamente sobre quais informações precisam ser preservadas, em quanto tempo elas devem ser restauradas e qual a quantidade de dados que pode ser perdida sem comprometer o negócio (Kolbe Junior, 2020).

O ponto de partida é a definição de dois parâmetros essenciais – o RTO (recovery time objective) e o RPO (recovery point objective). O quadro 2 apresenta a definição desses parâmetros e exemplos práticos.

Quadro 2 – Definição e exemplo prático de RTO e RPO

PARÂMETRO	DEFINIÇÃO	EXEMPLO PRÁTICO
RTO	Tempo máximo permitido para restaurar um sistema ou serviço após uma falha.	Uma loja virtual define que seu site deve voltar a funcionar em até 2 horas após uma queda para não perder vendas significativas.
RPO	Quantidade máxima de dados que pode ser perdida, medida a partir do último backup válido.	Um banco estipula que a perda máxima aceitável de dados de transações é de 15 minutos, realizando backups incrementais nesse intervalo.

Fonte: Zgureanu (2022).

Com RTO e RPO definidos, o planejamento deve especificar a frequência dos backups, os responsáveis por sua execução, o local de armazenamento (interno, externo ou em nuvem) e as ferramentas utilizadas. A ISO/IEC 27040:2024 (que é uma norma internacional que trata da proteção de armazenamento de dados) recomenda também controles de segurança como criptografia, autenticação de acesso e proteção física das mídias (ISO, 2024).

Outro ponto-chave é testar periodicamente o processo de restauração. De nada adianta ter múltiplas cópias se elas não puderem ser recuperadas dentro dos prazos estabelecidos. Empresas maduras nesse processo realizam simulações de recuperação total ao menos uma vez ao ano e testes parciais em intervalos menores.

Por fim, um bom planejamento de backup e recuperação está diretamente conectado à estratégia de continuidade de negócios. Ele garante que, diante de incidentes como falhas técnicas, ataques cibernéticos ou desastres naturais, a organização mantenha a disponibilidade, a integridade e a confidencialidade das informações críticas, preservando sua operação e reputação.

2.1 Armazenamento de backups: on-premises e em cloud

O armazenamento de backups pode ser realizado de duas formas principais: em infraestrutura local (on-premises) ou em serviços de nuvem (cloud). Cada abordagem apresenta vantagens e desafios específicos, e a escolha adequada depende do perfil da organização, do volume de dados, do orçamento disponível e das exigências regulatórias (Araújo Neto, 2023).

O backup on-premises consiste em manter cópias de segurança dentro da própria infraestrutura da organização, geralmente em servidores, fitas magnéticas ou dispositivos dedicados. Dentre os benefícios estão o controle total sobre os dados, a menor dependência de terceiros e a possibilidade de restaurar rapidamente informações em casos de falha local. No entanto, esse modelo demanda investimento em hardware, espaço físico e manutenção, além de planos de contingência para proteger os dados contra desastres naturais ou incidentes de segurança interna (Machado, 2014).

Por outro lado, o backup em nuvem oferece escalabilidade e flexibilidade, permitindo que a empresa armazene grandes volumes de dados sem precisar investir em infraestrutura física. Serviços de nuvem frequentemente incluem criptografia de ponta a ponta, redundância geográfica e monitoramento contínuo, facilitando a conformidade com normas de proteção de dados. É importante, porém, avaliar aspectos como a confiabilidade do provedor, custos de longo prazo e velocidades de upload e download, que podem impactar o tempo de recuperação (Araújo Neto, 2023).

Em muitos casos, organizações adotam um modelo híbrido, combinando backups on-premises e cloud. Essa abordagem permite restaurar de forma rápida dados críticos localmente e, ao mesmo tempo, garantir proteção contra desastres que afetam a infraestrutura física, aproveitando a redundância e a segurança proporcionadas pela nuvem. Por exemplo, uma empresa de serviços financeiros pode manter backups diários em

servidores internos para restaurações imediatas e backups semanais em nuvem para proteção contra incêndios ou falhas catastróficas.

A decisão entre on-premises, cloud ou híbrido deve sempre considerar o RTO e o RPO definidos previamente, de modo que o tempo de restauração e a quantidade de dados perdida permaneçam dentro dos limites aceitáveis para a operação da organização (Araújo Neto, 2023).

2.2 Estratégias de recuperação de dados em desastres

Desastres podem assumir diversas formas, desde falhas de hardware e corrupção de sistemas até eventos externos, como incêndios, enchentes ou ataques cibernéticos. Para cada cenário, é necessário ter estratégias bem-definidas que assegurem a rápida restauração das operações e minimizem impactos sobre clientes, colaboradores e parceiros (Konopczyk, 2022).

Nesse contexto, uma das abordagens mais comuns é o plano de recuperação de desastres DRP (disaster recovery plan). Ele estabelece procedimentos detalhados para identificar incidentes, acionar equipes responsáveis e restaurar sistemas críticos. Esse plano deve contemplar a restauração de dados e a continuidade operacional, incluindo hardware alternativo, redes de comunicação e softwares essenciais.

A partir da utilização do DRP, destacam-se as seguintes estratégias, apresentadas no quadro 3.

Quadro 3 – Estratégias de recuperação de dados

ESTRATÉGIA	DESCRIÇÃO	EXEMPLO PRÁTICO
Backup redundante	Manter cópias adicionais dos dados em locais diferentes, garantindo disponibilidade caso um site seja comprometido.	Empresa de comércio eletrônico mantém backups locais e em nuvem para assegurar continuidade em caso de falha no servidor principal.

(cont.)

ESTRATÉGIA	DESCRIÇÃO	EXEMPLO PRÁTICO
Restauração por prioridade	Identificar sistemas e informações críticas que devem ser recuperados primeiro, alinhando ao RTO e RPO definidos.	Sistemas de atendimento ao cliente e transações financeiras são restaurados antes de arquivos administrativos.
Testes periódicos de recuperação	Realizar simulações regulares para validar se procedimentos e backups funcionam conforme esperado.	Simulações anuais de recuperação total e testes mensais de sistemas críticos em um banco.
Automação e monitoramento	Utilizar soluções automatizadas de restauração, alertas em tempo real e dashboards de monitoramento, reduzindo erros humanos.	Softwares de backup que enviam alertas imediatos sobre falhas e permitem acompanhar a restauração de dados em tempo real.

Fonte: Stephen (2023).

É importante ressaltar que a recuperação de desastres inclui tecnologia, comunicação com stakeholders, documentação clara de procedimentos e treinamento das equipes. Por exemplo, em um hospital, não basta restaurar prontuários eletrônicos; a equipe precisa saber como acessar os sistemas temporariamente, registrar atendimentos manualmente e garantir que nenhum dado crítico seja perdido durante a transição.

Ao integrar essas estratégias, a organização cria uma estrutura resiliente capaz de enfrentar incidentes imprevistos, proteger informações críticas e manter a continuidade das operações, reforçando a confiança de clientes, parceiros e órgãos reguladores (Machado, 2014; Kolbe Junior, 2020).

3 Integração com a gestão de riscos

A integração das práticas de backup e privacidade de dados à gestão de riscos é um passo decisivo para fortalecer a resiliência operacional de uma organização. Ao reconhecer que informações digitais são ativos estratégicos, o gerenciamento de riscos passa a incorporar não apenas medidas técnicas, mas também diretrizes de governança que assegurem a proteção desses recursos.

De acordo com Kolbe Junior (2020), o planejamento de cópias de segurança e a preservação da privacidade precisam estar conectados a políticas que mapeiem riscos e definam procedimentos claros para prevenção, resposta e recuperação.

Em termos práticos, essa integração significa que as rotinas de backup não devem ser tratadas como processos isolados, mas sim como componentes de um sistema mais amplo, voltado para garantir a continuidade do negócio mesmo diante de incidentes inesperados. Assim, ao incorporar a análise de riscos, a escolha do tipo de backup, a frequência das cópias e a forma de armazenamento passam a ser decisões estratégicas, considerando variáveis como tempo de recuperação, volume de dados críticos e requisitos de conformidade.

Outro ponto relevante é que a gestão de riscos fornece uma estrutura metodológica para priorizar recursos e esforços. Isso é importante porque, em ambientes corporativos complexos, nem todos os dados possuem o mesmo grau de relevância ou sensibilidade. Machado (2014) observa que, quando se avalia o impacto potencial de uma perda de informação, torna-se possível determinar quais sistemas exigem backup em alta frequência, quais podem ser protegidos com métodos menos onerosos e quais precisam de controles mais rigorosos de privacidade, como criptografia e segregação lógica.



IMPORTANTE

No contexto da tecnologia da informação, riscos podem incluir falhas de hardware, ataques cibernéticos, erros humanos ou até desastres naturais que comprometam a disponibilidade e a integridade dos dados. É nesse ponto que o backup entra como medida de gestão de riscos: ao manter cópias de segurança das informações, a organização reduz a probabilidade de perda definitiva de dados e minimiza os impactos de incidentes, assegurando a continuidade das operações.

Integrar backup e privacidade à gestão de riscos ajuda a criar uma cultura organizacional voltada à prevenção. Quando colaboradores compreendem a importância das políticas, reconhecem seu papel no cumprimento das diretrizes e seguem procedimentos de forma consistente, os processos deixam de depender exclusivamente de tecnologia e passam a contar com um componente humano ativo na defesa das informações. Essa abordagem colaborativa amplia a eficácia das medidas técnicas e reforça a capacidade da organização de se adaptar a novos desafios.

3.1 Relacionamento entre privacidade e segurança de dados

A privacidade e a segurança de dados, embora tratem de aspectos distintos, são interdependentes no contexto da gestão de riscos em TI. A privacidade está relacionada ao direito do titular de ter suas informações coletadas, processadas e armazenadas de maneira legítima, transparente e para finalidades específicas, enquanto a segurança refere-se ao conjunto de medidas técnicas e administrativas destinadas a proteger esses dados contra acesso, uso ou divulgação não autorizados (Brasil, 2018).

Sem segurança adequada, não há como garantir a privacidade; e sem políticas claras de privacidade os esforços de segurança podem ser mal direcionados. Segundo Kolbe Junior (2020), a segurança de dados atua como um escudo para as informações, estabelecendo barreiras contra ameaças internas e externas, ao passo que a privacidade direciona como e por que esses dados podem ser utilizados.

Como bom exemplo, podemos citar um banco de dados de clientes que pode ser protegido por criptografia e controles de acesso robustos. Contudo, se as informações forem compartilhadas sem consentimento ou utilizadas para fins diferentes daqueles previamente autorizados, a privacidade estará comprometida, mesmo com medidas de segurança eficientes.

Varela (2020) complementa que, no ambiente corporativo, essa relação deve ser vista como uma via de mão dupla. A implementação de controles técnicos, como autenticação multifator, segmentação de redes e monitoramento de acessos, fortalece a segurança e, indiretamente, protege a privacidade. Ao mesmo tempo, a adoção de políticas de consentimento informado, regras de retenção e exclusão de dados e classificação de informações contribui para orientar os mecanismos de segurança, indicando quais ativos demandam maior nível de proteção.

A segurança garante a integridade e a disponibilidade das informações, enquanto a privacidade assegura que seu uso esteja alinhado às expectativas e direitos do titular.

Para Machado (2014), a chave para manter esse equilíbrio está na integração das políticas de segurança e privacidade dentro de um mesmo arcabouço de governança. Essa integração garante que cada decisão técnica seja sustentada por critérios éticos e legais, reduzindo o risco de vazamentos, uso indevido e exposição indevida de dados, além de aumentar a confiança de clientes, parceiros e demais partes interessadas.

3.2 Monitoramento contínuo e revisão de políticas

Manter políticas de backup e privacidade de dados alinhadas ao contexto atual da organização exige acompanhamento constante e ajustes periódicos. À medida que as tecnologias evoluem, novas ameaças surgem e as exigências regulatórias se modificam, o que foi definido em um determinado momento pode deixar de atender plenamente às necessidades da operação (Kolbe Junior, 2020).

O monitoramento contínuo permite observar como as rotinas de backup estão sendo executadas, se a frequência definida está sendo cumprida e se os mecanismos de segurança permanecem eficazes. Kolbe Junior (2020) aponta que sistemas de auditoria e alertas automáticos ajudam a identificar falhas como cópias incompletas, atrasos nas

execuções ou tentativas de acesso não autorizado. Essas ocorrências, quando detectadas rapidamente, podem ser corrigidas antes que causem prejuízos.

A revisão de políticas, por sua vez, envolve avaliar periodicamente se os objetivos originais continuam coerentes com o cenário atual. Alterações como a adoção de novas plataformas de gestão, a ampliação do volume de dados processados ou mudanças na infraestrutura de TI podem exigir a atualização das diretrizes. Machado (2014) destaca que essa revisão deve ser registrada e comunicada de forma clara às equipes, evitando interpretações equivocadas que comprometam a efetividade das medidas.

Há casos em que o próprio crescimento da organização provoca a necessidade de ajustes. Um exemplo ocorre quando novos serviços digitais passam a operar com dados sensíveis, exigindo maior frequência de backup e reforço nos controles de acesso. Situações desse tipo demonstram que o monitoramento e a revisão não são processos isolados, mas etapas que se retroalimentam, garantindo que as políticas se mantenham coerentes com as prioridades da gestão de riscos e as exigências legais vigentes.

3.3 Indicadores de desempenho (KPIs) para gestão de riscos

Medir a eficácia das políticas de backup e privacidade de dados é uma tarefa que exige o uso de indicadores objetivos, capazes de traduzir em números ou percentuais o desempenho das ações implementadas. Esses indicadores, conhecidos como KPIs (key performance indicators), permitem avaliar se as práticas adotadas estão alcançando os resultados esperados, além de fornecer subsídios para ajustes e melhorias.

Os KPIs funcionam como um painel de controle para a gestão de riscos, facilitando a visualização de tendências e a identificação de falhas

antes que gerem impactos significativos. Para que cumpram esse papel, precisam ser claros, mensuráveis e relevantes para os objetivos estratégicos da organização.

O quadro 4 apresenta alguns exemplos de KPIs aplicáveis à gestão de backup e privacidade de dados, com breve descrição e possíveis aplicações.

Quadro 4 – Exemplos de KPIs

KPI	DESCRIÇÃO	APLICAÇÃO
Tempo médio de recuperação (RTO – recovery time objective)	Tempo necessário para restaurar sistemas e dados após um incidente.	Avaliar se a velocidade de recuperação atende ao tempo máximo tolerado pela operação.
Frequência de execução de backups	Percentual de backups realizados dentro da periodicidade definida na política.	Verificar aderência às rotinas e identificar atrasos ou falhas de execução.
Taxa de sucesso na restauração	Percentual de backups que puderam ser restaurados com sucesso em testes.	Medir a confiabilidade das cópias armazenadas.
Volume de dados protegidos	Quantidade de dados efetivamente incluídos nas rotinas de backup em relação ao total armazenado.	Garantir que todos os dados críticos estejam cobertos.
Incidentes de segurança envolvendo dados sensíveis	Número de ocorrências de acesso ou vazamento de dados classificados como sensíveis.	Monitorar a eficácia dos controles de segurança aplicados à privacidade.

Fonte: elaboração do autor (2025).

A utilidade dos KPIs não está apenas na coleta de dados, mas na interpretação e no uso dessas informações para aprimorar as políticas. Por exemplo, se o tempo médio de recuperação (RTO) estiver acima do aceitável, a organização pode investir em soluções de backup mais ágeis ou revisar suas prioridades de restauração.

A análise periódica desses indicadores deve fazer parte de um ciclo de melhoria contínua, no qual cada resultado serve de base para novos ajustes. Essa abordagem garante que a gestão de riscos permaneça alinhada à realidade operacional e às expectativas de clientes, parceiros e órgãos reguladores.

Considerações finais

Ao longo deste capítulo, ficou evidente que a segurança e a preservação das informações dependem de um conjunto articulado de medidas técnicas e organizacionais. A definição de políticas estruturadas de backup e de privacidade de dados deve ser acompanhada por ações estratégicas que envolvem governança, atendimento a normas regulatórias e fortalecimento da cultura interna de proteção à informação.

A clareza nas diretrizes, a definição de parâmetros como RTO e RPO, a escolha criteriosa de soluções de armazenamento e a implementação de planos de recuperação diante de falhas ou desastres são fatores que, quando aplicados de forma integrada, contribuem para reduzir riscos e garantir maior resiliência frente a incidentes.

O tratamento da privacidade dos dados, sobretudo no caso de informações sensíveis, deve se estender também ao ambiente de backup, assegurando que as cópias mantidas recebam o mesmo nível de proteção e controle aplicado aos dados originais. Nesse cenário, a aderência a legislações específicas e a boas práticas reconhecidas internacionalmente amplia a credibilidade da organização e fortalece a confiança de clientes, parceiros e demais interessados.

Quando incorporadas ao processo de gestão de riscos, as rotinas de backup e de privacidade permitem que os recursos sejam priorizados de acordo com a importância de cada sistema ou dado. Essa prática, sustentada por monitoramento contínuo, revisão periódica e avaliação de indicadores de desempenho, transforma a proteção da informação em

um processo dinâmico, capaz de se ajustar às mudanças tecnológicas, ao surgimento de novas ameaças e às exigências regulatórias em constante evolução.

Dessa forma, investir na segurança da informação significa investir na continuidade das operações e na própria sustentabilidade do negócio. Empresas que compreendem essa relação e estruturam seus processos de maneira consistente reduzem perdas, protegem sua imagem institucional e reafirmam seu compromisso ético e legal com a proteção da privacidade, alcançando assim maior competitividade em um mercado cada vez mais orientado pelo uso estratégico dos dados.

Referências

ARAÚJO NETO, A. P. **Arquitetura de data center**. São Paulo: Editora Senac São Paulo, 2023.

BARRETO, J. S.; ZANIN, A.; MORAIS, I. S.; VETTORAZZO, A. S. **Fundamentos de segurança da informação**. Porto Alegre: Sagah, 2018.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). **Diário Oficial da União**: seção 1, Brasília, DF, ano 156, n. 157, p. 59-64, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 14 ago. 2025.

ISO/IEC 27040:2024. **Tecnologia da informação — Técnicas de segurança — Segurança de armazenamento**. Geneva: International Organization for Standardization, 2024. Disponível em: <https://www.iso.org/standard/80194.html>. Acesso em: 14 ago. 2025.

KOLBE JÚNIOR, A. **Sistemas de segurança da informação na era do conhecimento**. Curitiba: Intersaberes, 2017.

KONOPCZYK, M. G. **Riscos, auditoria e resposta a incidentes**. São Paulo: Editora Senac São Paulo, 2022.

MACHADO, F. N. R. **Segurança da informação**: princípios e controle de ameaças. São Paulo: Érica, 2014.

PEGETTI, A. **Gestão da segurança da informação**. São Paulo: Editora Senac São Paulo, 2022.

VARELA, W. A. **Infraestrutura de TI**. São Paulo: Editora Senac São Paulo, 2020.

STEPHEN, M. Data Backup Strategies in Disaster Recovery: Ensuring Minimal Downtime. **IEEE Transactions on Cloud Computing**, Piscataway, 2023.

ZGUREANU, A. The role of RPO and RTO in disaster recovery planning. *In*: INTERNATIONAL SCIENTIFIC CONFERENCE “30 YEARS OF ECONOMIC REFORMS IN THE REPUBLIC OF MOLDOVA: ECONOMIC PROGRESS VIA INNOVATION AND COMPETITIVENESS”, 2022, Chisinau. **Proceedings...** Chisinau: Academy of Economic Studies of Moldova, 2022. Disponível em: <https://irek.ase.md/xmlui/handle/123456789/2074>. Acesso em: 14 ago. 2025.

